

Duoc UC

3.1.1 Pentesting: Pruebas de Seguridad Software

Guía completa sobre la ejecución y análisis de pruebas de penetración

Contenido

01 Introducción al Pentesting

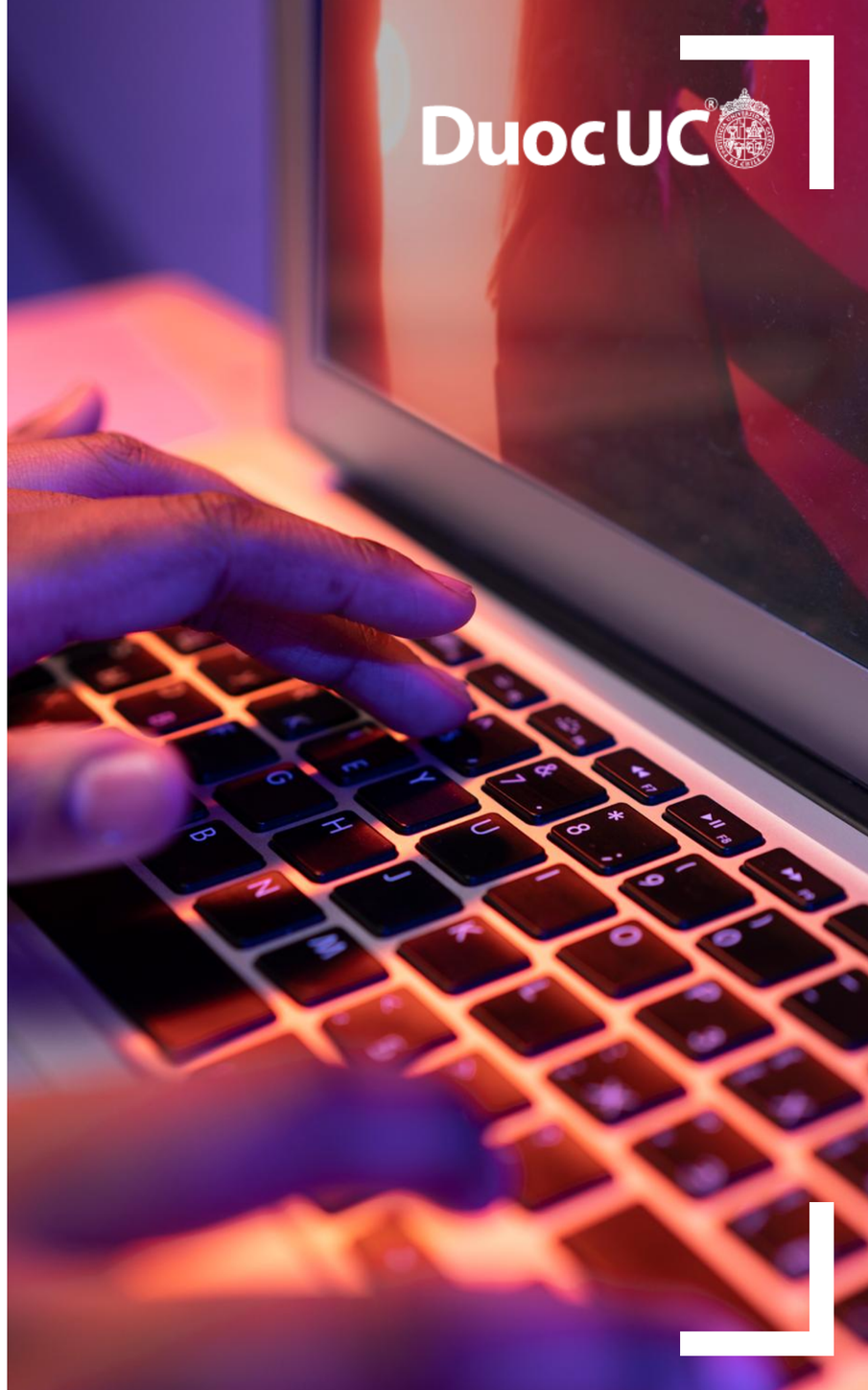
02 Tipos de Pentesting

03 Metodología de Ejecución

04 Vectores de Ataque Comunes

05 Herramientas y Certificaciones

06 El Informe de Resultados



02

Pentesting: Pruebas de Seguridad de Software

Guía completa sobre la ejecución y análisis de pruebas de penetración en entornos digitales.

¿Por qué el Pentesting es tu mejor inversión?

En un mundo digital moderno, no se trata de **si** serás atacado, sino de **cuándo**. En 2023, el costo promedio global de una brecha de datos alcanzó los **$4.5 millones de dólares**. El pentesting no es solo un "ataque simulado"; es la herramienta proactiva que te permite encontrar tus debilidades antes de que un actor malicioso las explote.

"La seguridad no es un producto, es un proceso dinámico de evolución continua".

1. Introducción al Pentesting: Definición y objetivos estratégicos



¿Qué es el Pentesting?

El pentesting, o prueba de penetración, es un **ataque informático simulado y controlado** realizado por profesionales de seguridad autorizados. Su objetivo principal es identificar vulnerabilidades en sistemas, redes, aplicaciones web y otros activos digitales antes de que actores maliciosos puedan explotarlas.

A diferencia de un ataque real, el pentesting se ejecuta con el consentimiento explícito de la organización propietaria del sistema, siguiendo metodologías estructuradas y con el fin último de fortalecer la postura de seguridad de la empresa.



Objetivos Principales del Pentesting

Identificar Vulnerabilidades

Descubrir fallos de seguridad en sistemas, aplicaciones y configuraciones antes de que sean explotados

Evaluar Defensas

Probar la efectividad de los controles de seguridad existentes y las capacidades de respuesta ante incidentes

Proporcionar Evidencias

Documentar hallazgos con pruebas concretas y recomendaciones prácticas para la remediación

Cumplir Normativas

Satisfacer requisitos de auditoría y certificaciones de seguridad como ISO 27001 o PCI DSS

Tipos de Pentesting

Tipos de Pentesting según el Conocimiento Previo

1	2	3
Black Box (Caja Negra) El pentester no tiene información previa sobre el sistema objetivo. Simula un ataque externo realista donde el atacante debe descubrir toda la información por sí mismo, desde la superficie de ataque hasta las vulnerabilidades internas.	White Box (Caja Blanca) Se proporciona acceso completo a información técnica: código fuente, diagramas de arquitectura, credenciales y documentación. Permite una evaluación exhaustiva y profunda de todos los componentes del sistema.	Grey Box (Caja Gris) Enfoque híbrido donde se proporciona información parcial, como credenciales de usuario básico o documentación limitada. Simula amenazas internas o ataques de empleados con acceso limitado al sistema.

Metodologia del Pentesting

Metodología del Pentesting

01

Reconocimiento

Recopilación de información sobre el objetivo

02

Escaneo

Identificación de puertos, servicios y sistemas activos

03

Enumeración

Obtención detallada de recursos y configuraciones

04

Explotación

Aprovechamiento de vulnerabilidades detectadas

05

Post-explotación

Evaluación del impacto y persistencia en el sistema

06

Documentación

Elaboración del informe con hallazgos y recomendaciones

Fase 1: Reconocimiento

Reconocimiento Pasivo Actividades que no interactúan directamente con el objetivo, evitando su detección:

- Exploración en motores de búsqueda y redes sociales
- Análisis de registros DNS públicos
- Consulta de bases de datos WHOIS
- Revisión de código fuente en repositorios abiertos
- Identificación de tecnologías mediante herramientas OSINT

Reconocimiento Activo Acciones que implican interacción directa con el sistema objetivo, con mayor riesgo de ser detectadas:

- Escaneo de puertos y servicios expuestos
- Fingerprinting de sistemas operativos
- Pruebas de ingeniería social
- Enumeración de subdominios activos
- Mapeo de la infraestructura de red

Esta fase inicial es crítica para comprender el entorno del objetivo y diseñar estrategias de ataque efectivas.

Fase 2: Escaneo y Análisis

Durante esta etapa, se emplean herramientas especializadas para identificar servicios activos, versiones de software y posibles vulnerabilidades presentes en la superficie de ataque.

Herramientas de Escaneo

- **Nmap**: Detección de puertos abiertos y servicios activos
- **Nessus**: Análisis automatizado de vulnerabilidades conocidas
- **Nikto**: Evaluación de seguridad en servidores web
- **Burp Suite**: Pruebas de seguridad en aplicaciones web

Información Recolectada

- Puertos abiertos y servicios expuestos
- Versiones de software y sistemas operativos detectados
- Configuraciones inseguras o mal implementadas
- Certificados SSL y políticas de seguridad asociadas

Esta fase permite construir un perfil técnico del objetivo, facilitando la identificación de vectores de ataque y priorización de riesgos.

Fase 3: Explotación de Vulnerabilidades

Una vez identificadas las vulnerabilidades, el pentester ejecuta una explotación controlada para demostrar su impacto real y validar los riesgos asociados.

Selección de Objetivos Priorización de vulnerabilidades según su criticidad, facilidad de explotación y valor estratégico del activo comprometido.
Uso de Exploits Aplicación de técnicas y herramientas como **Metasploit**, **SQLmap** o scripts personalizados para explotar las debilidades detectadas.
Obtención de Acceso Acceso no autorizado a sistemas, datos o funcionalidades críticas, evidenciando el alcance potencial del compromiso.
Documentación Técnica Registro detallado de cada paso del proceso, incluyendo comandos utilizados, capturas de pantalla y evidencias del acceso logrado.

Esta fase permite validar escenarios de riesgo, fortalecer controles defensivos y generar recomendaciones precisas para mitigar vulnerabilidades.

Tipos de Vulnerabilidades Comunes

Aplicaciones Web Amenazas que afectan directamente la lógica y seguridad de las aplicaciones expuestas en internet:
•Inyección SQL
•Cross-Site Scripting (XSS)
•Cross-Site Request Forgery (CSRF)
•Mecanismos de autenticación débiles
•Exposición de datos sensibles

Infraestructura Debilidades en la configuración y mantenimiento de los sistemas que soportan los servicios:
•Servicios obsoletos o sin soporte
•Configuraciones por defecto no modificadas
•Contraseñas débiles o reutilizadas
•Ausencia de segmentación en la red
•Puertos abiertos innecesarios

Factor Humano Riesgos derivados del comportamiento, formación y cultura organizacional:
•Técnicas de ingeniería social
•Campañas de phishing y spear phishing
•Falta de concienciación en seguridad
•Uso compartido de credenciales
•Políticas de seguridad inexistentes o ineficaces

La gestión integral de estos tres vectores —tecnológico, estructural y humano— es esencial para fortalecer la postura de seguridad de cualquier organización.

Herramientas Esenciales para Pentesting



Kali Linux

Distribución Linux especializada que incluye más de 600 herramientas de seguridad preinstaladas. Es el sistema operativo estándar para profesionales del pentesting.



Burp Suite

Herramienta integral para pruebas de seguridad en aplicaciones web. Incluye proxy interceptor, scanner automático y extensiones personalizables.



John the Ripper

Herramienta de cracking de contraseñas que utiliza ataques de diccionario, fuerza bruta y reglas personalizadas para descifrar hashes.



Metasploit Framework

Plataforma de explotación más utilizada mundialmente. Contiene miles de exploits verificados y módulos para post-explotación y pivoting.



Wireshark

Analizador de protocolos de red que permite capturar y examinar el tráfico en tiempo real, identificando información sensible transmitida sin cifrado.



Social Engineering Toolkit

Framework especializado en ataques de ingeniería social, incluyendo phishing, spear phishing y vectores de ataque basados en el factor humano.

Pausa Activa: Momento de Reflexión

- **Pregunta:** Si una organización tarda, en promedio, **277 días** en detectar una brecha de seguridad, ¿qué impacto tendría en tu empresa que un atacante tuviera acceso total a tus sistemas críticos durante 9 meses antes de ser descubierto?

- **Reflexión:** Considera que el **95% de los incidentes** son causados por error humano.

¿Es suficiente con tener el mejor Firewall si tus empleados no están capacitados?

DuocUC

Vectores de Ataque Comunes

Pentesting de Aplicaciones Web

Las aplicaciones web son uno de los vectores de ataque más comunes. El pentesting web se enfoca en identificar vulnerabilidades específicas de este entorno.

OWASP Top 10

Marco de referencia que identifica las 10 vulnerabilidades más críticas en aplicaciones web, actualizado regularmente por la comunidad de seguridad global.

Pruebas de Autenticación

Evaluación de mecanismos de login, gestión de sesiones, recuperación de contraseñas y controles de autorización para prevenir accesos no autorizados.

Validación de Entradas

Verificación de la correcta sanitización de datos para prevenir inyecciones SQL, XSS, XXE y otras técnicas de inyección de código malicioso.



Pentesting de Infraestructura

1

Perímetro Externo

Evaluación de firewalls, IDS/IPS, VPNs y sistemas expuestos a Internet. Identificación de servicios vulnerables y configuraciones inseguras en la DMZ.

2

Red Interna

Análisis de segmentación de red, Active Directory, políticas de grupo y servicios internos. Evaluación de movimientos laterales y escalada de privilegios.

3

Sistemas Críticos

Pruebas específicas en servidores, bases de datos, sistemas de control industrial (ICS/SCADA) y otros activos de alta criticidad para el negocio.

4

Dispositivos IoT

Evaluación de dispositivos conectados, firmware, protocolos de comunicación y controles de acceso en el ecosistema del Internet de las Cosas.

Ingeniería Social en Pentesting

El factor humano continúa siendo el eslabón más vulnerable en la cadena de seguridad. La ingeniería social se basa en manipular la psicología y el comportamiento de las personas para obtener acceso no autorizado a sistemas, datos o información confidencial.



Técnicas Comunes:

•**Phishing**: Correos electrónicos fraudulentos que simulan comunicaciones legítimas para inducir al usuario a revelar información sensible.
•**Vishing**: Llamadas telefónicas engañosas que buscan obtener datos confidenciales mediante persuasión verbal.
•**Pretexting**: Creación de escenarios falsos para generar confianza y justificar la solicitud de información.
•**Baiting**: Ofrecimiento de objetos atractivos (como dispositivos USB o premios) que inducen al usuario a realizar acciones inseguras.
•**Tailgating**: Acceso físico no autorizado aprovechando el ingreso de empleados legítimos sin verificación de credenciales.

La concienciación y formación continua del personal son claves para mitigar estos riesgos y fortalecer la seguridad organizacional.

DuocUC

Informes y Resultados

El Informe de Pentesting

El informe final es el entregable más importante del proceso. Debe ser claro, accionable y adaptado a diferentes audiencias técnicas y ejecutivas.

Resumen Ejecutivo

Visión de alto nivel del estado de seguridad, nivel de riesgo general y recomendaciones estratégicas para la dirección de la empresa.

Metodología

Descripción del enfoque utilizado, alcance del proyecto, limitaciones encontradas y herramientas empleadas durante las pruebas.

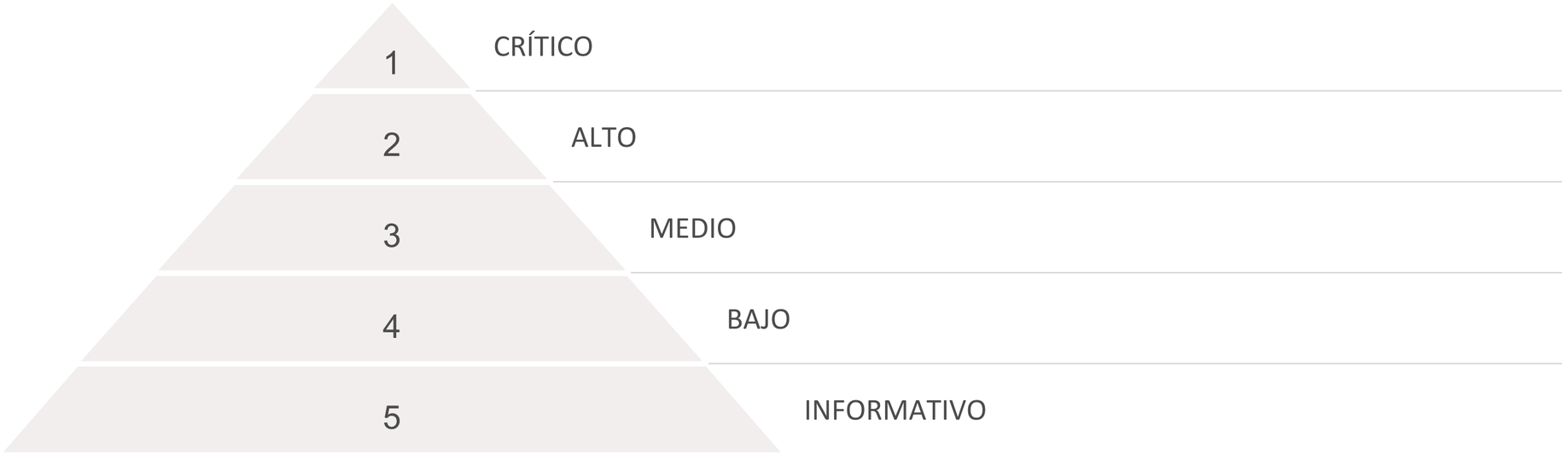
Hallazgos Técnicos

Detalle de cada vulnerabilidad encontrada con clasificación de criticidad (crítica, alta, media, baja), evidencias, pasos de reproducción y vectores de explotación.

Recomendaciones

Soluciones específicas priorizadas por impacto y esfuerzo de implementación, incluyendo parches, cambios de configuración y mejores prácticas.

Clasificación de Riesgos



La clasificación de vulnerabilidades se basa en el impacto potencial al negocio y la facilidad de explotación. Los hallazgos críticos requieren acción inmediata, mientras que los informativos son observaciones de mejora.

Estadísticas de Ciberseguridad

43%

Ataques a PYMEs

Porcentaje de ciberataques dirigidos a pequeñas y medianas empresas, que frecuentemente carecen de recursos de seguridad adecuados

$4.5M

Costo Promedio

Costo medio global de una brecha de datos en 2023, incluyendo pérdidas operativas, legales y reputacionales

277

Días para Detectar

Tiempo promedio que tarda una organización en identificar una brecha de seguridad desde su inicio

95%

Error Humano

Porcentaje de incidentes de seguridad causados por error humano, destacando la importancia de la capacitación

IBM Security. "Cost of a Data Breach Report 2023".
Verizon. "Data Breach Investigations Report 2023".
Ponemon Institute. "2023 State of Cybersecurity Report".

Marco Legal y Ético del Pentesting

Autorización Explícita

Es **fundamental** contar con autorización por escrito antes de iniciar cualquier prueba. Realizar pentesting sin permiso constituye un delito de acceso no autorizado a sistemas informáticos.

Acuerdos de Confidencialidad

Los pentesters deben firmar NDAs (Non-Disclosure Agreements) para proteger la información sensible descubierta durante las pruebas y mantener la privacidad del cliente.

Límites del Alcance

El contrato debe especificar claramente qué sistemas están dentro del alcance, qué técnicas están permitidas y qué acciones están prohibidas durante las pruebas.

Código Ético Profesional

Los profesionales deben adherirse a estándares éticos como los definidos por EC-Council, OWASP y otras organizaciones de ciberseguridad reconocidas internacionalmente.



Certificaciones Profesionales en Pentesting



CEH - Certified Ethical Hacker

Certificación de EC-Council que cubre fundamentos de hacking ético, reconocida globalmente por empleadores en el sector de ciberseguridad.



OSCP - Offensive Security Certified Professional

Certificación práctica altamente respetada que requiere comprometer múltiples máquinas en un entorno de laboratorio real durante 24 horas.



GPEN - GIAC Penetration Tester

Certificación de SANS Institute que valida habilidades en pruebas de penetración, incluyendo metodologías de ataque y análisis de vulnerabilidades.

Futuro del Pentesting

Tendencias Emergentes

Pentesting Automatizado con IA

Herramientas impulsadas por inteligencia artificial que pueden identificar patrones de vulnerabilidades y adaptarse dinámicamente

Seguridad en la Nube

Mayor enfoque en pruebas de entornos AWS, Azure, GCP y arquitecturas de microservicios containerizados

IoT y Dispositivos Conectados

Expansión de las pruebas hacia el ecosistema creciente de dispositivos inteligentes y sistemas embebidos



Conclusión: El Primer Paso hacia la Resiliencia

Has finalizado este módulo introductorio, ¡felicitaciones!. Ahora entiendes que el pentesting es un pilar estratégico de la ciberseguridad moderna. Sin embargo, el panorama de amenazas evoluciona cada día con la Inteligencia Artificial y el crecimiento del IoT.

Tu camino no termina aquí. Te invitamos a profundizar en las metodologías de OWASP para aplicaciones web o a iniciar tu preparación para certificaciones internacionales como CEH o OSCP. Fortalecer tu conocimiento es la única forma de elevar la madurez de seguridad de tu organización.

¿Te gustaría que profundice en los detalles técnicos de alguna de las fases de la metodología de pentesting?

Bibliografía

Referencias de Organismos e Informes Globales

- **IBM Security**: "Cost of a Data Breach Report 2023".
- **Verizon**: "Data Breach Investigations Report 2023".
- **Ponemon Institute**: "2023 State of Cybersecurity Report".
- **OWASP (Open Web Application Security Project)**: Marco de referencia para las 10 vulnerabilidades más críticas en aplicaciones web (OWASP Top 10).

Estándares y Certificaciones Internacionales

- **ISO 27001**: Estándar internacional para sistemas de gestión de seguridad de la información.
- **PCI DSS**: Estándar de seguridad de datos para la industria de tarjetas de pago.
- **EC-Council**: Código ético y certificación *Certified Ethical Hacker* (CEH).
- **Offensive Security**: Certificación práctica *Offensive Security Certified Professional* (OSCP).
- **SANS Institute / GIAC**: Certificación *GIAC Penetration Tester* (GPEN)[9].

Herramientas Técnicas de Referencia

- **Kali Linux**: Sistema operativo estándar para profesionales del pentesting.
- **Metasploit Framework**: Plataforma de explotación de vulnerabilidades.
- **Burp Suite**: Herramienta integral para pruebas de seguridad en aplicaciones web.
- **Nmap / Nessus / Nikto**: Herramientas especializadas en escaneo de puertos y análisis de vulnerabilidades.



Felicitaciones

¡Has finalizado el módulo!

ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

<> ESCUELA DE **INFORMÁTICA Y TELECOMUNICACIONES**

DuocUC®

CERCANÍA. LIDERAZGO. FUTURO.

7 AÑOS ACREDITADO

Comisión Nacional de Acreditación CNA-Chile

NIVEL DE EXCELENCIA

HASTA OCTUBRE 2031

Docencia de pregrado / Gestión institucional / Aseguramiento interno de la calidad / Vinculación con el Medio / Investigación, creación y/o innovación